

EPICODE

Corso di Cybersecurity

Social Engineering & Phishing

Report tecnico — Campagna di Spear Phishing assistita da AI

Studente: Giuseppe Carbone

Data: 5 maggio 2026

Obiettivo	Riconoscere vettori di attacco di ingegneria sociale, dall'analisi delle email di phishing al rilevamento dei deepfake audio, implementando analisi basate sull'IA.
Target	Federica Russo (target concordato e autorizzato)
Ambiente	Kali Linux (WSL2 su Windows 11) + Gophish
Data esercizio	5 maggio 2026

1. Obiettivi dell'Esercitazione

L'esercitazione ha come scopo la progettazione e l'esecuzione di una campagna di spear phishing credibile, con l'ausilio dell'intelligenza artificiale, verso un target concordato e autorizzato. L'obiettivo e' verificare in modo pratico i principali vettori di attacco basati su ingegneria sociale, dalla costruzione di un'email convincente alla creazione di una landing page fittizia, misurando la risposta del target.

Attivita' svolte

- Progettazione dell'email di spear phishing con assistenza AI (Claude / ChatGPT)
- Creazione di una landing page fittizia che imita le impostazioni account di Meta/Instagram
- Hosting della landing page su GitHub Pages (repository pubblica)
- Configurazione di Gophish come piattaforma di invio e tracciamento campagna
- Configurazione SMTP tramite account Gmail personale con App Password
- Lancio della campagna e monitoraggio delle statistiche in tempo reale
- Analisi del comportamento del target e documentazione dei risultati

2. Definizione del Target

Per questa esercitazione e' stato selezionato un target concordato, nel rispetto delle norme etiche e legali applicabili alle attivita' di penetration testing. Il target ha espresso il proprio consenso a partecipare all'esercizio.

Campo	Valore
Nome target	Federica Russo
Email target	fede272007@gmail.com
Profilo social	fede__russo_ (Instagram)
Tipo attacco	Spear Phishing — tema Instagram/Meta
Consenso	SI — target concordato e informato a posteriori
Ambiente operativo	Kali Linux (WSL2) + Gophish 0.12
Data esercizio	05/05/2026

3. Raccolta OSINT sul Target (Pre-Attack)

Prima di progettare la campagna e' stata effettuata una fase di ricognizione passiva sul target, raccogliendo informazioni pubblicamente disponibili attraverso i social network e Google Dorking. Questa fase e' fondamentale nello spear phishing per personalizzare il messaggio e renderlo credibile.

3.1 Informazioni raccolte

Fonte	Informazione raccolta	Utilizzo nell'attacco
Instagram	Username: fede__russo_	Inserito nell'email come destinatario personalizzato
Instagram	Account attivo e recente	Credibilita' del pretesto (modifica password)
Gmail	Indirizzo email pubblico	Destinatario della campagna Gophish
Meta/Instagram	Interfaccia grafica impostazioni	Modello per la landing page fittizia

4. Progettazione dell'Email di Spear Phishing

L'email e' stata progettata con l'ausilio dell'intelligenza artificiale (Claude di Anthropic) per massimizzare la credibilita' e il senso di urgenza. Il tema scelto e' la notifica di sicurezza di Instagram — uno dei pretesti piu' efficaci nell'ingegneria sociale perche' sfrutta la paura di perdere l'accesso al proprio account.

4.1 Criteri di progettazione

- Personalizzazione: username reale del target (fede__russo_) nell'intestazione
- Urgenza: linguaggio che implica un'azione richiesta immediata
- Credibilita' visiva: logo Instagram, layout e colori originali replicati fedelmente
- Pretesto: notifica di verifica identita' — classico vettore di social engineering
- CTA (Call to Action): codice di verifica e link per la modifica password

4.2 Struttura dell'email

L'email e' stata costruita come template HTML in Gophish, replicando graficamente le comunicazioni ufficiali di Instagram. Il mittente apparente era **giuseppelinux14@gmail.com** configurato con SMTP Gmail.

Mittente (apparente)	security@instagram.com (spoofed)
Oggetto	Authenticate your profile
Destinatario	fede272007@gmail.com
Corpo	Hi fede__russo_, Someone tried to modify settings on your Instagram profile. Use the following code to confirm your identity: 26591299 If this wasn't you, reset your password.
Logo	Instagram (logo ufficiale incluso nel template HTML)
Link tracciato	https://[ngrok-url]/?rid=[tracking_id]

4.3 Ruolo dell'AI nella progettazione

L'intelligenza artificiale (Claude) e' stata utilizzata nelle seguenti fasi:

- Generazione del testo dell'email: formulazione di un messaggio convincente che imita il tono ufficiale di Instagram
- Ottimizzazione del layout HTML: struttura visiva fedele alle email originali Meta
- Iniezione del modal di modifica password: script JavaScript per aprire il popup al click del bottone
- Risoluzione di problematiche tecniche: configurazione SMTP, ngrok, Gophish

5. Creazione della Landing Page Fittizia

La landing page fittizia replica fedelmente l'interfaccia delle impostazioni account di Meta/Instagram — in particolare la sezione 'Password e Sicurezza'. E' stata creata salvando la pagina originale dal browser e modificandola con l'aggiunta di un modal JavaScript personalizzato.

5.1 Metodologia di creazione

Passo 1 — Acquisizione

Salvataggio della pagina HTML autentica di Instagram Account Center tramite browser (Salva con nome > Pagina web completa)

Passo 2 — Modifica AI

Utilizzo di Claude per iniettare un modal HTML/CSS/JS che replica il popup 'Modifica password' mostrato nello screen originale

Passo 3 — Hosting

Upload della pagina e della cartella assets su un repository GitHub pubblico: github.com/zeniith14/meta

Passo 4 — Pubblicazione

Abilitazione di GitHub Pages sul repository — URL finale: <https://zeniith14.github.io/meta/>

Passo 5 — Integrazione

URL inserito nel campo 'URL' della campagna Gophish per il redirect tracciato

5.2 Caratteristiche tecniche della landing page

Caratteristica	Dettaglio
URL pubblico	https://zeniith14.github.io/meta/
Hosting	GitHub Pages (gratuito, HTTPS automatico)
Tecnologia	HTML statico + JavaScript vanilla
Replica visiva	Interfaccia Meta Account Center — sezione Password e Sicurezza
Modal aggiunto	Popup 'Modifica password' con campi: password attuale, nuova password, ripeti passwor
Redirect post-submit	https://mediamente.my.canva.site/sei-stata-hackerata
Capture passwords	Abilitato in Gophish (Capture Submitted Data + Capture Passwords)

6. Infrastruttura di Attacco — Gophish + ngrok

La campagna e' stata orchestrata tramite Gophish, una piattaforma open-source per la simulazione di campagne di phishing. Per rendere il server locale raggiungibile dall'esterno e' stato utilizzato ngrok come tunnel HTTPS.

6.1 Stack tecnologico

Componente	Tecnologia	Ruolo
Phishing Framework	Gophish 0.12	Invio email, tracking click/open/submit
SMTP	Gmail (App Password)	Server di invio email autenticato
Tunnel pubblico	ngrok (Free Plan)	Espone Gophish su URL HTTPS pubblico
Landing Page	GitHub Pages	Hosting pagina fittizia Meta
OS	Kali Linux (WSL2)	Ambiente operativo
AI Assistente	Claude (Anthropic)	Supporto tecnico e progettazione contenuti

6.2 Configurazione Gophish

Il file config.json e' stato modificato per esporre il phishing server su HTTP porta 80:

```
{ "phish_server": { "listen_url": "0.0.0.0:80", "use_tls": false } }
```

Gophish e' stato poi avviato come servizio systemd. ngrok ha creato il tunnel HTTPS:

```
$ ngrok http 80 Forwarding: https://april-sprang-earmuff.ngrok-free.dev -> http://localhost:80
```

6.3 Configurazione campagna

Parametro	Valore
Nome campagna	meta
Email Template	fedes (template Instagram autenticazione)
Landing Page	meta (pagina HTML fittizia)
URL campagna	https://april-sprang-earmuff.ngrok-free.dev
Sending Profile	meta (Gmail SMTP)
Gruppo destinatari	Federica Russo, fortniteginocamioncino@gmail.com
Data lancio	05/05/2026 ore 13:28

7. Risultati della Campagna

Metrica	Valore	Note
Email Inviare	3	Federica Russo + 2 account di controllo
Email Ricevute	3 / 3	Consegna al 100%
Email Aperte	1 (confermato)	Aperta da Federica Russo — tracking pixel bloccato da Gmail
Link Cliccati	0	Problema ngrok risolto a campagna gia' inviata
Credenziali Inviare	0	Target non ha proseguito (esercizio concordato)
Email Segnalate	0	Nessuna segnalazione spam

7.1 Analisi del comportamento del target

Federica Russo ha aperto l'email ricevuta — confermato dalla sua stessa osservazione diretta. L'email aveva un aspetto sufficientemente credibile da non essere ignorata immediatamente. Il target non ha proseguito con il click sul link o l'inserimento di credenziali in quanto era a conoscenza dell'esercizio (test concordato). In uno scenario reale, la consegna riuscita dell'email e la sua apertura rappresenterebbero gia' un risultato significativo per un attaccante.

7.2 Efficacia del pretesto

Elemento	Efficacia	Motivazione
Logo Instagram	Alta	Replica visiva fedele del brand
Username personalizzato	Alta	Crea senso di legittimita' e familiarita'
Codice di verifica numerico	Media-Alta	Elemento di autenticita' tipico delle notifiche reali
Lingua inglese	Media	Piu' credibile per notifiche Meta/Instagram
Mittente Gmail visibile	Bassa	Un utente attento nota che non e' un dominio @instagram.com

8. Analisi Tecnica del Vettore di Attacco

8.1 Diagramma del flusso di attacco

Il flusso completo dell'attacco segue questa sequenza:

1. OSINT PASSIVO: raccolta username Instagram e indirizzo email del target
2. PREPARAZIONE: creazione template email con AI + landing page fittizia su GitHub Pages
3. INFRASTRUTTURA: configurazione Gophish + Gmail SMTP + ngrok tunnel
4. INVIO: campagna lanciata — email consegnata alla vittima
5. INTERAZIONE: vittima apre l'email (tracking pixel / conferma diretta)
6. REDIRECT: se vittima clicca il link -> ngrok -> Gophish -> GitHub Pages
7. HARVEST: se vittima inserisce credenziali -> Gophish cattura e salva in chiaro
8. REDIRECT FINALE: vittima viene reindirizzata a pagina 'sei-stata-hackerata'

8.2 Indicatori di Compromissione (IoC)

IoC	Tipo	Valore
Mittente email	Email spoofed	giuseppelinux14@gmail.com
URL campagna	Dominio ngrok	april-sprang-earmuff.ngrok-free.dev
Landing page	GitHub Pages	zeniith14.github.io/meta/
Redirect page	Canva site	mediamente.my.canva.site/sei-stata-hackerata
User-Agent	Gophish default	GoPhish

8.3 Contromisure che avrebbero bloccato l'attacco

Contromisura	Avrebbe bloccato
Controllo del dominio mittente	Email non proveniva da @instagram.com o @meta.com
SPF/DKIM/DMARC sul dominio Meta	Gmail avrebbe marcato l'email come spoofed
Browser con Safe Browsing attivo	Avrebbe segnalato il dominio ngrok come sospetto
Autenticazione a 2 fattori (2FA)	Le credenziali rubate sarebbero inutilizzabili da sole
Consapevolezza del phishing	Riconoscimento dell'email come tentativo di phishing

9. Conclusioni

L'esercitazione ha dimostrato come sia possibile costruire una campagna di spear phishing credibile e funzionale utilizzando esclusivamente strumenti open-source gratuiti e l'assistenza dell'intelligenza artificiale.

La fase di consegna dell'email ha avuto successo al 100%: tutte e 3 le email sono state recapitate e quella indirizzata a Federica Russo e' stata aperta. Questo conferma l'efficacia del pretesto scelto (notifica sicurezza Instagram) e della qualita' grafica del template.

Il fattore limitante principale e' stato il mittente visibile (un indirizzo Gmail generico anziche' un dominio @instagram.com), che un utente attento avrebbe riconosciuto come sospetto. In uno scenario di attacco reale avanzato, l'attaccante utilizzerebbe tecniche di domain spoofing o un dominio lookalike (es. instagram-security.com) per aumentare ulteriormente la credibilita'.